

Autenticação Contextual Autônoma para Aplicações Web Combinando um Ensemble de IA e Auditoria em Blockchain Permissionada

João Guedes de Brito

Programa de Pós-Graduação em Engenharia de Sistemas e Produtos (PPGESP)

Instituto Federal da Bahia (IFBA)

Salvador, Bahia, Brasil

joaoguedesdebrito@gmail.com

Cleber Jorge Lira de Santana

Programa de Pós-Graduação em Engenharia de Sistemas e Produtos (PPGESP)

Instituto Federal da Bahia (IFBA)

Salvador, Bahia, Brasil

cleberlira@ifba.edu.br

Resumo—Mecanismos tradicionais de autenticação baseados em senhas estáticas ou em autenticação multifator (MFA) fixa permanecem amplamente adotados, mas ignoram o contexto comportamental e ambiental de cada tentativa de acesso e são cada vez mais explorados por ataques de *credential stuffing*, phishing e tomada de conta. Este artigo apresenta um sistema autônomo de autenticação contextual para aplicações web que combina um ensemble de aprendizado de máquina com auditoria em blockchain permissionada. Cada login é descrito por quatorze critérios contextuais e comportamentais, avaliados por um ensemble de Isolation Forest, Random Forest e uma rede neural multicamada; o escore de risco resultante conduz uma decisão adaptativa em três faixas (permitir, reforçar com MFA ou bloquear). Cada decisão é registrada de forma imutável em uma rede Hyperledger Fabric, gerando uma trilha de auditoria verificável e de não repúdio, cuja necessidade frente a logs assinados e bancos append-only é explicitamente justificada. Em avaliação controlada sobre um conjunto de dados sintéticos com cerca de 50.000 registros de login (95% legítimos, 5% suspeitos), o ensemble alcançou 98,1% de acurácia, 80,2% de F1-score e AUC-ROC de 0,99 no conjunto de teste, com taxa de falsos positivos de 0,8% e latência de inferência de aproximadamente 33 ms por requisição. Esses resultados são preliminares e baseiam-se em dados sintéticos; caracterizam a viabilidade técnica da abordagem, e não um estudo de campo, devendo ser confirmados com dados reais.

Index Terms—autenticação contextual, autenticação baseada em risco, aprendizado de máquina, ensemble, detecção de anomalias, blockchain, trilha de auditoria, segurança da informação.

I. INTRODUÇÃO

A autenticação é a primeira linha de defesa de aplicações web. Historicamente, apoiou-se em um fator de conhecimento — a senha —, cujas fragilidades são amplamente documentadas: senhas são reutilizadas entre serviços, vazadas em larga escala e exploradas por força bruta, *credential stuffing* e phishing [1], [2]. A autenticação multifator (MFA) mitiga parte

dessa exposição ao combinar fatores de conhecimento, posse e inerência, mas a MFA estática ainda sucumbe a engenharia social, troca de chip (SIM swapping) e interceptação de códigos em tempo real, além de introduzir atrito na experiência do usuário [1].

A escala do problema justifica ir além da credencial. *Credential stuffing*, phishing e o uso de credenciais roubadas seguem entre os principais vetores em relatórios de incidentes, e a fraude por tomada de conta impõe custos financeiros e reputacionais diretos a organizações e usuários finais [2]. A reutilização de senhas transforma qualquer vazamento isolado em um passivo entre serviços, enquanto ferramentas de ataque comoditizadas tornam o abuso de login em larga escala barato e altamente automatizado. Sobretudo, defesas estáticas — políticas de robustez de senha e códigos de uso único — não observam *como*, *quando* ou *de onde* ocorre um login e, portanto, não distinguem um usuário legítimo de um adversário que já detém credenciais válidas. Marcos regulatórios como a LGPD [21] acrescentam um requisito adicional: decisões automatizadas de acesso sobre dados pessoais precisam ser comprovadamente auditáveis. Em conjunto, essas pressões motivam decisões de autenticação condicionadas ao contexto completo de cada tentativa — e que deixem uma trilha verificável do *porquê* de cada decisão.

Para enfrentar essas limitações, as diretrizes de identidade digital do NIST e o modelo de Zero Trust recomendam mecanismos *adaptativos*, nos quais o nível de verificação exigido é proporcional ao risco estimado de cada tentativa [1], [3]. Isso desloca a autenticação de uma decisão binária e estática para uma avaliação contínua e sensível ao contexto — abordagem conhecida na literatura como autenticação baseada em risco (*Risk-Based Authentication*, RBA). Estudos empíricos de serviços em produção mostram, contudo, que o RBA implantado é dominado por um único sinal (tipicamente

o endereço IP) e por heurísticas ajustadas manualmente [4], [5]. Em paralelo, quando as decisões de acesso são delegadas a modelos autônomos, elas precisam ser *auditáveis* por terceiros (por exemplo, em fiscalizações de conformidade), requisito que registros de decisão sob a guarda de um único operador não atendem plenamente.

Este artigo propõe um sistema autônomo de autenticação contextual que unifica, em um único fluxo, uma decisão adaptativa por aprendizado de máquina (ML) e sua auditoria imutável. As principais contribuições são:

- uma arquitetura ponta a ponta que funde quatorze critérios contextuais e comportamentais em um único escore de risco calculado por um ensemble de Isolation Forest, Random Forest e rede neural, conduzindo uma decisão adaptativa em três faixas;
- uma camada de auditoria em blockchain permissionada acoplada à decisão, com justificativa explícita do *porquê* da necessidade de blockchain frente a logs assinados ou bancos append-only; e
- uma metodologia de avaliação reprodutível, com baselines e um estudo preliminar de viabilidade sobre dados sintéticos.

O restante do artigo organiza-se assim. A Seção II revisa os trabalhos correlatos. A Seção III descreve a arquitetura proposta; a Seção IV, o motor de IA; e a Seção V, a camada de auditoria em blockchain. A Seção VI apresenta a metodologia de avaliação e a Seção VII, os resultados. A Seção VIII conclui.

II. TRABALHOS CORRELATOS

Biometria comportamental. A autenticação contínua a partir de padrões de interação está bem estabelecida. O TypeNet [11] e o TypeFormer [12] identificam usuários pela dinâmica de digitação com baixas taxas de erro, e o Touchalytics [13] mostra que padrões de toque discriminam usuários em dispositivos móveis. Esses trabalhos confirmam o poder discriminativo do comportamento do usuário, mas concentram-se em uma única modalidade biométrica e não tratam da auditoria imutável das decisões. Surveys recentes de autenticação contínua baseada em sensores [9] corroboram que sinais comportamentais generalizam por diversas modalidades, ao mesmo tempo em que apontam desafios em aberto de robustez, envelhecimento de template e implantação real — desafios que reforçam a fusão do comportamento com outros sinais contextuais em vez da dependência de uma única modalidade.

Sinais contextuais e de dispositivo. Além do comportamento, o contexto de dispositivo e rede de um login é, por si só, discriminativo. Alaca e van Oorschot [7] classificam vinte e nove métodos de fingerprinting de dispositivo para reforçar a autenticação web, comparando-os por estabilidade, dificuldade de spoofing e distinguibilidade, e Andriamilanto *et al.* [8] mostram, em mais de quatro milhões de navegadores, que fingerprints de navegador carregam distinguibilidade e estabilidade suficientes para reforçar a autenticação. Freeman *et al.* [6] introduziram o primeiro modelo probabilístico público que classifica um login como normal ou suspeito a partir

de sinais como IP de origem, geolocalização, configuração do navegador e hora do dia. Esses trabalhos validam sinais contextuais individuais, mas os tratam em grande parte de forma isolada e não acoplam a decisão resultante a um registro à prova de adulteração.

Autenticação baseada em risco. Wiefeling *et al.* [4] conduziram o primeiro estudo empírico de larga escala sobre RBA em serviços reais, e trabalhos posteriores [5] mostraram que os fatores de risco devem ser cuidadosamente ajustados por serviço. Nossa proposta segue essa linha, mas substitui heurísticas fixas — e os modelos de sinal único, pontuados estatisticamente, que as precederam [6] — por um ensemble de ML multissinal e adiciona uma camada de não repúdio.

Deteção de anomalias. O Isolation Forest [14] é referência para detecção não supervisionada de outliers em alta dimensionalidade, e modelos supervisionados e profundos [16] o complementam quando há rótulos; Killourhy e Maxion [15] estabeleceram um marco metodológico para a detecção de anomalias em dinâmica de digitação. Combinamos ambas as naturezas — não supervisionada e supervisionada — em um ensemble.

Blockchain para auditoria. Embora a auditoria de logs baseada em blockchain venha sendo investigada, a maioria das abordagens trata o registro de eventos de forma *desacoplada* do mecanismo de decisão. Sistemas como o BlockAudit [10] demonstram trilhas de auditoria escaláveis e à prova de adulteração em blockchain, mas os eventos registrados originam-se em aplicações externas à camada de registro, de modo que o registro atesta *que* um evento ocorreu sem vinculá-lo ao raciocínio que o produziu. O diferencial deste trabalho é integrar, em um único fluxo, a decisão adaptativa por IA e o seu registro imutável em rede permissionada, de modo que cada entrada armazenada carregue os próprios critérios e o escore que justificaram a ação. A Tabela I sintetiza trabalhos representativos: nenhuma linha de pesquisa reúne simultaneamente (i) a fusão de múltiplos sinais contextuais e comportamentais, (ii) a decisão adaptativa por ensemble e (iii) a auditoria imutável acoplada à decisão.

III. ARQUITETURA PROPOSTA

A arquitetura articula microsserviços, gestão federada de identidade, análise de risco por IA e registro imutável em blockchain, seguindo os princípios de segurança por desenho e verificação contínua do Zero Trust [3], [20]. Em vez de uma decisão binária no momento do login, o modelo adota uma perspectiva contínua e orientada a risco. Organiza-se em cinco camadas integradas (Fig. 1):

- 1) **Aplicação Modular.** Serviços independentes (Spring Boot) e front end Angular expõem APIs REST autenticadas.
- 2) **Identidade e Acesso.** Autenticação federada via Keycloak (OAuth2 / OpenID Connect), emissão de JWT e suporte a MFA.
- 3) **Inteligência Contextual.** Extração dos quatorze critérios comportamentais e cálculo do escore de risco pelo ensemble.

Tabela I
POSICIONAMENTO FRENTE A TRABALHOS CORRELATOS
REPRESENTATIVOS

Trabalho	Sinais	Adapt.	Audit.	Dados
TypeNet [11]	Digitação	✓	—	Real
Touchalytics [13]	bloqueio	✓	—	Real
Freeman [6]	IP/geo/UA	Parc.	—	Real
Alaca [7]	Fp. disp.	—	—	—
Andriam. [8]	Fp. nav.	—	—	Real
RBA [4]	IP/contexto	Parc.	—	Real
Iso. Forest [14]	Genérico	N. sup.	—	—
BlockAudit [10]	Logs	—	✓	—
Este trab.	14	Ens.	✓	Sint.
	ctx.+comp.			

Adapt.: decisão adaptativa/aprendida (Parc.: parcial; N. sup.: não supervisionada; Ens.: ensemble). *Audit.*: auditoria imutável acoplada à decisão.

- 4) **Decisão Adaptativa.** Aplicação dos limiares de risco, resultando em *permitir*, *reforçar com MFA* ou *bloquear*.
- 5) **Registro Imutável e Auditoria.** Persistência de cada decisão em blockchain permissionada, garantindo rastreabilidade e não repúdio.

O fluxo operacional é uma cadeia decisória encadeada: a tentativa de login dispara a extração dos critérios contextuais; o motor de IA calcula o escore de risco; os limiares de decisão são aplicados; o resultado é registrado na blockchain; e o sistema permite o acesso, exige MFA ou o bloqueia. A separação em camadas permite evoluir cada responsabilidade de forma independente e aplicar políticas de segurança específicas em cada nível.

Modelo de ameaças e racional de projeto. O sistema pressupõe um adversário que pode já deter credenciais válidas — obtidas por vazamento, phishing ou reutilização — e que pode tentar logins a partir de redes e dispositivos arbitrários, mas que não consegue forjar o consenso da rede permissionada nem observar o estado privado dos modelos de risco. Sob esse modelo, as camadas tratam preocupações complementares: a C2 estabelece *quem* alega autenticar-se, a C3 estima *quão provável* é que a alegação seja legítima dado o contexto, a C4 converte a estimativa em uma ação proporcional e a C5 torna a ação *prestável de contas*. Desacoplar a estimativa (C3) da aplicação (C4) é deliberado: os limiares de risco podem ser recalibrados, e os modelos reentreinados, sem tocar no provedor de identidade, e a camada de auditoria permanece agnóstica aos aprendizes específicos em uso. Como cada decisão é registrada junto com sua justificativa — o hash dos critérios de entrada e o escore que o produziu —, um auditor pode reproduzir posteriormente qualquer decisão e verificar que a ação registrada corresponde à política vigente naquele momento, sem precisar confiar nos próprios logs do operador. É esse acoplamento estreito entre *decidir* e *registrar* que distingue a proposta de pipelines que registram eventos depois, e separadamente, da decisão.

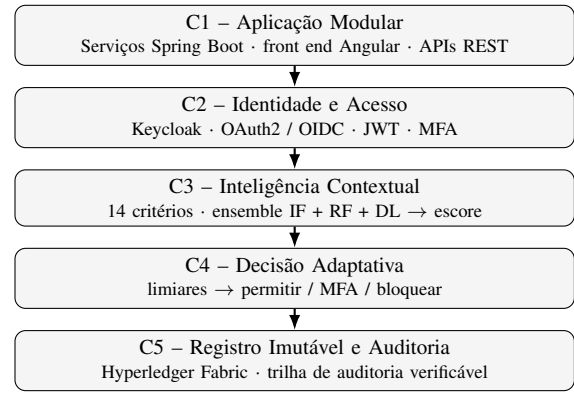


Figura 1. Arquitetura em cinco camadas do sistema proposto.

IV. MOTOR DE DECISÃO POR IA

Ensemble. O motor de risco combina três aprendizes complementares. O *Isolation Forest* [14] atua como primeiro nível de análise, isolando outliers no espaço multidimensional de critérios com poucas partições aleatórias; contribui com 40% do peso final. O *Random Forest* contribui com 30%, capturando relações não lineares entre os critérios e mantendo-se interpretável. Uma *rede neural multicamada* [16] contribui com os 30% restantes, com camada de entrada de 14 neurônios, duas camadas ocultas (64 e 32 unidades, ativações ReLU, regularização por dropout) e saída sigmoid. O escore final é a média ponderada

$$S = 0,4 S_{IF} + 0,3 S_{RF} + 0,3 S_{DL}, \quad (1)$$

em que cada componente retorna um valor em $[0, 1]$ (0: normal, 1: altamente anômalo). A combinação de aprendizes não supervisionados e supervisionados aumenta a robustez tanto a ataques inéditos (zero-day) quanto a fraudes conhecidas.

Crítérios. Cada tentativa é representada por quatorze critérios em quatro famílias: *temporais* (hora do acesso em escala circular, dia da semana, intervalo desde o último login, frequência em 24 h); *geográficos/rede* (distância geodésica do local habitual, tipo de rede, ASN, velocidade de deslocamento impossível); *dispositivo/navegador* (fingerprint do navegador, sistema operacional, tipo de dispositivo, detecção de automação/headless); e *comportamento de sessão* (padrão de digitação e histórico de falhas recentes). Esses sinais visam credential stuffing, viagem impossível, sequestro de sessão, bots e desvios zero-day.

Limiares adaptativos. O escore é mapeado em três faixas de risco, calibradas empiricamente para equilibrar segurança e usabilidade: baixo risco ($S < 0,3$) permite o acesso sem etapas adicionais; risco moderado ($0,3 \leq S < 0,7$) aciona MFA; e alto risco ($S \geq 0,7$) bloqueia a tentativa, registra o evento na blockchain e notifica o administrador de segurança. Em produção, o motor é exposto como um microserviço REST independente consumido pelo backend, mantendo os três modelos em memória para inferência paralela. Um mecanismo de fallback heurístico preserva a disponibilidade caso o serviço

de IA fique inacessível. Os modelos são reentreinados periodicamente para acompanhar a mudança de comportamento (concept drift) [17], e todo modelo treinado é versionado para permitir rollback.

V. AUDITORIA BASEADA EM BLOCKCHAIN

Cada decisão é registrada de forma imutável em uma rede permissionada baseada em Hyperledger Fabric [18], cujo controle de identidade e governança estruturada são adequados a ambientes corporativos e governamentais [19]. Para cada evento, o registro armazena o hash dos critérios de entrada, o escore de risco, a decisão (permitir, MFA ou bloquear) e o timestamp da transação, encadeado ao registro anterior de modo a formar uma cadeia cronológica de evidências.

A escolha do blockchain frente a mecanismos mais simples é justificada, e não presumida. Logs assinados digitalmente e bancos append-only já oferecem integridade e não repúdio por meio de assinaturas criptográficas, sendo suficientes quando existe uma autoridade central confiável que opera o registro. A diferença essencial de um blockchain permissionado *não* está na assinatura em si, mas em não depender da confiança em um único custodiante: o registro é replicado e validado por consenso entre múltiplos participantes, tornando-se resistente à adulteração mesmo por administradores privilegiados do próprio sistema e permitindo verificação independente por auditores externos. Isso é determinante aqui, pois as decisões de acesso são tomadas de forma autônoma por modelos de IA e precisam ser auditáveis por terceiros (por exemplo, em fiscalizações de conformidade da LGPD [21]), cenário em que o operador, sozinho, não deve poder alterar a trilha de decisões. Reconhece-se o custo — maior complexidade operacional e menor throughput do que um banco append-only —, que se justifica justamente em cenários multipartes e regulados, delimitando o escopo em que o blockchain é efetivamente necessário.

VI. METODOLOGIA DE AVALIAÇÃO

Dados e rotulagem. Diante da ausência de bases públicas rotuladas para autenticação contextual, construiu-se um conjunto de dados sintéticos com cerca de 50.000 registros de login,¹ reproduzindo a distribuição observada em produção (cerca de 95% de acessos legítimos e 5% suspeitos). Cada registro contém os quatorze critérios da Seção IV. Os rótulos foram derivados de regras heurísticas que codificam padrões conhecidos de fraude (viagem impossível, dispositivo desconhecido, rajadas de falhas de login) e revisados por especialistas em segurança. O processo gerador amostra cada registro legítimo a partir de distribuições calibradas para o uso corporativo típico: a hora de acesso segue uma gaussiana centrada no meio do dia, o intervalo entre logins uma lei exponencial, a frequência em 24 horas uma contagem de Poisson e a distância geodésica uma meia-normal concentrada próxima ao local habitual; os escores de impressão digital do navegador e de similaridade de digitação são gaussianas de média alta,

enquanto os indicadores de dispositivo, sistema operacional e tipo de rede seguem as frequências categóricas observadas em produção. Os registros suspeitos são obtidos perturbando de dois a cinco critérios de um perfil de outro modo legítimo para faixas anômalas — velocidades de viagem impossível, dispositivos desconhecidos, indicadores de automação e rajadas de falhas recentes — de modo que as anomalias permaneçam multivariadas e se sobreponham parcialmente à classe legítima, em vez de serem trivialmente separáveis. Em seguida, adiciona-se uma quantidade calibrada de ruído gaussiano a cada critério para reproduzir a sobreposição de classes esperada na prática, e cerca de 5% dos registros legítimos recebem uma anomalia branda em um único critério, o que produz os falsos positivos realistas refletidos na FPR reportada. Por se tratar de dados sintéticos, não há coleta de informações pessoais identificáveis nesta fase; a evolução para dados reais seguirá os princípios de minimização e anonimização exigidos pela LGPD [21].

Protocolo. O conjunto foi particionado de forma estratificada em 70% para treinamento e 30% para teste. Validação cruzada estratificada com 5 folds foi aplicada sobre a partição de treinamento para seleção de hiperparâmetros, reservando a partição de teste exclusivamente para a avaliação final, evitando vazamento de dados (data leakage). O desempenho foi medido por acurácia, precisão, recall, F1-score, taxa de falsos positivos (FPR), AUC-ROC e latência de decisão. As sementes aleatórias foram fixadas, os modelos e hiperparâmetros versionados, e todo o ambiente foi containerizado (Docker/Kubernetes) para reprodução determinística. Para permitir verificação independente, o código-fonte, os artefatos dos modelos treinados e os scripts que geram o conjunto de dados e reproduzem cada experimento estão abertamente disponíveis.²

Reprodutibilidade. Um único script de entrada regenera todo o pipeline de forma determinística a partir da semente fixa: o conjunto rotulado (50.000 registros com os quatorze critérios e o rótulo de classe), os três modelos treinados juntamente com o normalizador de atributos (serializados com `joblib`), a configuração do ensemble (pesos dos componentes, os limites de normalização do escore da Isolation Forest e o limiar de decisão selecionado pelo melhor F1 de treinamento) e um arquivo de métricas legível por máquina contendo cada valor reportado na Seção VII. Reexecutar o script em um ambiente limpo reproduz as métricas reportadas a menos da variação desprezível introduzida pelo otimizador estocástico da rede neural, de modo que um revisor possa auditar todo o pipeline de ponta a ponta — da geração dos atributos brutos ao limiar de decisão final — sem acesso a quaisquer dados privados ou pessoalmente identificáveis. Esse empacotamento é o que transforma a descrição de “cerca de 50.000 registros” em um artefato que um terceiro pode regenerar, inspecionar e estender.

Baselines. A Tabela II confronta a proposta com baselines representativos da literatura e da prática. Os valores dos baselines provêm da literatura citada e não foram reexecutados aqui; a comparação é, portanto, qualitativa quanto às capacidades

¹Conjunto de dados (CSV rotulado, modelos treinados e métricas): <https://github.com/jgbcientista/gestao-autonomo/tree/main/docs/artefatos-modelos>

²<https://github.com/jgbcientista/gestao-autonomo>

Tabela II
COMPARAÇÃO COM ABORDAGENS DE REFERÊNCIA

Abordagem	Ctx.	Adapt.	Audit.	Limitação principal
Senha + 2FA estático	—	—	—	Ignora contexto; phishing/SIM swap
RBA por IP [4]	Parc.	Heur.	—	Feature única; ajuste manual
Escore estatístico [6]	✓	Est.	—	Poucos sinais; sem auditoria
Keystroke isolado [15]	✓	—	—	Offline, fator único (EER $\approx 9,6\%$)
Proposta	✓	Ens.	✓	Adaptativa, explicável e auditável

Ctx.: usa contexto do login; *Adapt.*: decisão adaptativa (Heur.: heurística; Est.: estatística; Ens.: ensemble); *Audit.*: auditoria imutável acoplada à decisão.

de cada abordagem. Os três eixos de comparação não são arbitrários; decorrem dos requisitos que a literatura impõe à autenticação moderna. A *sensibilidade ao contexto* (Ctx.) reflete a recomendação do NIST e do modelo Zero Trust de que a verificação seja condicionada aos sinais de cada tentativa, e não apenas à credencial [1], [3], propriedade que estudos empíricos de autenticação baseada em risco apontam como decisiva na prática [4], [6]. A *adaptabilidade* (Adapt.) expressa se a resposta é proporcional ao risco estimado — princípio central da autenticação baseada em risco [1], [4], [5] — em vez de uma regra fixa. A *auditabilidade* (Audit.) trata da prestação de contas de decisões automatizadas sobre dados pessoais, exigência explicitada por regulações como a LGPD [21] e, de modo mais amplo, pela necessidade de verificação independente quando o acesso é delegado a modelos autônomos. Em conjunto, esses eixos cobrem as duas propriedades que um sistema de autenticação contextual precisa satisfazer simultaneamente — decidir corretamente e ser verificável —, enquanto a coluna *principal limitação* indica onde cada baseline falha em ao menos uma delas.

VII. RESULTADOS E DISCUSSÃO

Sobre o conjunto de teste (30% dos dados, não vistos durante o treinamento), o ensemble alcançou acurácia de 98,1%, precisão de 83,0% e recall de 77,6% na detecção de acessos suspeitos, com F1-score de 80,2% e AUC-ROC de 0,99, indicando forte capacidade de ordenação entre acessos legítimos e suspeitos. A taxa de falsos positivos manteve-se baixa, em 0,8%, fator relevante para a usabilidade. A validação cruzada estratificada com 5 folds confirmou a estabilidade dos resultados (acurácia $98,2\% \pm 0,1\%$; F1 $80,5\% \pm 0,8\%$). A Tabela III resume esses números.

Quanto à cadeia de autenticação, a integração entre o Keycloak e o serviço de ML foi validada com sucesso. A inferência do ensemble foi medida em cerca de 33 ms por requisição na máquina de referência (mediana de chamadas

Tabela III
DESEMPENHO DO ENSEMBLE NO CONJUNTO DE TESTE

Métrica	Valor	Métrica	Valor
Acurácia	98,1%	F1-score	80,2%
Precisão	83,0%	AUC-ROC	0,99
Recall	77,6%	Taxa falsos pos.	0,8%
Acurácia (5-fold)	98,2% $\pm$ 0,1%		
F1-score (5-fold)	80,5% $\pm$ 0,8%		
Latência do ensemble	≈ 33 ms/req.		

individuais, dominada pela Random Forest), muito abaixo do orçamento de 200 ms definido para o componente de IA; o fluxo completo de autenticação contextual — incluindo a validação de identidade e o registro em blockchain — permaneceu na ordem de algumas centenas de milissegundos. O pipeline de registro em blockchain mostrou-se consistente nos testes de imutabilidade, com validação criptográfica bem-sucedida em todas as transações registradas, e o ELK Stack e o Grafana permitiram a visualização em tempo real dos eventos de autenticação.

Discussão. Os resultados parciais são promissores e sugerem a viabilidade técnica da abordagem; contudo, por decorrerem de dados sintéticos e de uma fase preliminar, não permitem ainda confirmar a hipótese central de forma conclusiva. Uma comparação rigorosa com os baselines e a validação com dados reais permanecem necessárias antes de qualquer afirmação quantitativa de superioridade. O F1-score de 80,2%, embora adequado ao estágio atual, evidencia espaço para melhorar o recall quando os dados reais substituírem o conjunto sintético. Ainda assim, em ambiente controlado, a abordagem adaptativa e orientada a contexto detectou padrões de acesso suspeitos — como os cenários simulados de credential stuffing e sequestro de sessão — que escapam a sistemas baseados apenas em senha e 2FA estático, enquanto a camada de blockchain tornou inviável a adulteração retroativa dos registros sem detecção.

Análise de erros e compromissos. O limiar de decisão não é fixado a priori, mas selecionado como o valor que maximiza o F1-score na partição de treinamento, o que torna o ponto de operação explícito e ajustável por implantação: reduzi-lo aumenta o recall ao custo de mais desafios de step-up, ao passo que elevá-lo favorece uma experiência sem atrito ao risco de deixar escapar ataques limítrofes. No ponto escolhido, a matriz de confusão no conjunto de teste é dominada por verdadeiros negativos, e os erros residuais concentram-se na fronteira entre acessos legítimos levemente anômalos e acessos suspeitos de baixa intensidade — exatamente a região que o modelo de ruído foi projetado para tornar ambígua. Isso explica tanto o F1 abaixo de 90% quanto a baixa taxa de falsos positivos: o ensemble é conservador, preferindo uma detecção perdida ocasional a penalizar usuários legítimos, viés apropriado a um front-end de autenticação, em que o atrito de usabilidade tem custo direto de negócio. Os três modelos contribuem com visões complementares — a Isolation Forest sinaliza combi-

nações de atributos globalmente raras sem rótulos, enquanto a Random Forest e a rede neural exploram a fronteira de decisão rotulada —, de modo que a média ponderada degrada de forma graciosa quando qualquer modelo isolado está incerto. Evitamos deliberadamente ler esses números como evidência de superioridade sobre os baselines da Tabela II: os baselines não foram reexecutados sobre os mesmos dados, e o gerador sintético, por mais cuidadosamente calibrado, não captura toda a diversidade adversarial do tráfego de produção. Essas observações enquadram o experimento como um estudo de viabilidade cujo próximo passo é a validação sobre logs reais e não repudiáveis coletados sob a própria arquitetura aqui proposta.

Limitações e ameaças à validade. Três limitações delimitam o alcance das conclusões. Primeiro, a validade externa é restringida pelo uso de dados sintéticos: embora o processo gerador reproduza distribuições plausíveis de uso corporativo, ele não captura a cauda longa de comportamentos legítimos atípicos nem a criatividade adversarial observada em tráfego real, de modo que as métricas relatadas devem ser lidas como um limite superior otimista e não como desempenho esperado em produção. Segundo, a validade de construção depende da rotulagem heurística: por derivarem das mesmas regras que descrevem os padrões de fraude, os rótulos podem introduzir uma circularidade em que o ensemble reaprende as fronteiras codificadas no próprio gerador — risco que apenas a rotulagem sobre incidentes reais, revisada por analistas, elimina por completo. Terceiro, a comparação com os baselines é deliberadamente qualitativa, pois estes não foram reexecutados sobre o mesmo conjunto de dados; afirmações quantitativas de superioridade permanecem, portanto, fora do escopo desta fase preliminar. Mitigamos parcialmente essas ameaças fixando as sementes aleatórias, versionando os modelos e os hiperparâmetros e publicando abertamente os artefatos para inspeção independente; a superação plena, contudo, exige a coleta de logs reais e não repudiáveis sob a arquitetura proposta — precisamente o registro imutável que a camada de auditoria em blockchain fornece —, fechando o ciclo entre a avaliação metodológica e a operação efetiva do sistema.

VIII. CONSIDERAÇÕES FINAIS E TRABALHOS FUTUROS

Este artigo apresentou um sistema autônomo de autenticação contextual que unifica, em um único fluxo, uma decisão adaptativa por IA e sua auditoria imutável em blockchain permissionada. As principais contribuições são a arquitetura ponta a ponta que funde quatorze sinais contextuais e comportamentais por meio de um ensemble, a camada de auditoria acoplada à decisão com justificativa explícita para o uso de blockchain e uma metodologia de avaliação reproduzível. Experimentos preliminares sobre dados sintéticos indicaram viabilidade técnica (98,1% de acurácia, 80,2% de F1-score, AUC de 0,99, latência de inferência de ≈ 33 ms), constituindo uma validação metodológica e não um substituto para a avaliação com dados reais. Como trabalhos futuros, pretende-se substituir o conjunto sintético por dados reais ou semirreais coletados em ambiente controlado, refinar a calibração de

modelos e limiares, avaliar desempenho e escalabilidade sob carga realista e aprofundar a análise de segurança frente ao modelo de ameaças. Planeja-se ainda investigar a explicabilidade das decisões do ensemble — expondo, para cada bloqueio ou desafio de MFA, os critérios de maior contribuição ao escore de risco —, avaliar o comportamento do sistema sob deriva de conceito prolongada e ataques adversariais de evasão, e conduzir um estudo de usabilidade que quantifique o atrito percebido pelos usuários legítimos frente aos desafios adaptativos.

REFERÊNCIAS

- [1] National Institute of Standards and Technology, “Digital Identity Guidelines: Authentication and Lifecycle Management,” NIST SP 800-63B, 2017.
- [2] Verizon, “2024 Data Breach Investigations Report (DBIR),” Verizon Business, 2024.
- [3] S. Rose, O. Borchert, S. Mitchell, and S. Connelly, “Zero Trust Architecture,” NIST SP 800-207, 2020.
- [4] S. Wiefeling, L. Lo Iacono, and M. Dürmuth, “Is This Really You? An Empirical Study on Risk-Based Authentication Applied in the Wild,” in *IFIP SEC*, 2019, pp. 134–148.
- [5] S. Wiefeling, P. R. Jørgensen, S. Thunem, and L. Lo Iacono, “Pump Up Password Security! Evaluating and Enhancing Risk-Based Authentication on a Real-World Large-Scale Online Service,” *ACM Trans. Priv. Secur.*, vol. 26, no. 1, 2023.
- [6] D. Freeman, S. Jain, M. Dürmuth, B. Biggio, and G. Giacinto, “Who Are You? A Statistical Approach to Measuring User Authenticity,” in *Proc. Netw. Distrib. Syst. Secur. Symp. (NDSS)*, 2016.
- [7] F. Alaca and P. C. van Oorschot, “Device Fingerprinting for Augmenting Web Authentication: Classification and Analysis of Methods,” in *Proc. 32nd Annu. Comput. Secur. Appl. Conf. (ACSAC)*, 2016, pp. 289–301.
- [8] N. Andriamilanto, T. Allard, G. Le Guelvouit, and A. Garel, “A Large-scale Empirical Analysis of Browser Fingerprints Properties for Web Authentication,” *ACM Trans. Web*, vol. 16, no. 1, pp. 1–62, 2021.
- [9] M. Abuhamad, A. Abusnaina, D. Nyang, and D. Mohaisen, “Sensor-Based Continuous Authentication of Smartphones’ Users Using Behavioral Biometrics: A Contemporary Survey,” *IEEE Internet Things J.*, vol. 8, no. 1, pp. 65–84, 2021.
- [10] A. Ahmad, M. Saad, and A. Mohaisen, “Secure and Transparent Audit Logs with BlockAudit,” *J. Netw. Comput. Appl.*, vol. 145, art. 102406, 2019.
- [11] A. Acién, A. Morales, R. Vera-Rodríguez, J. Fierrez, and J. V. Monaco, “TypeNet: Deep Learning Keystroke Biometrics,” *IEEE Trans. Biom. Behav. Identity Sci.*, vol. 4, no. 1, pp. 57–70, 2022.
- [12] G. Stragapede *et al.*, “TypeFormer: Transformers for Mobile Keystroke Biometrics,” *Pattern Recognition Letters*, 2024.
- [13] M. Frank, R. Biedert, E. Ma, I. Martinovic, and D. Song, “Touchalytics: On the Applicability of Touchscreen Input as a Behavioral Biometric for Continuous Authentication,” *IEEE Trans. Inf. Forensics Security*, vol. 8, no. 1, pp. 136–148, 2013.
- [14] F. T. Liu, K. M. Ting, and Z.-H. Zhou, “Isolation Forest,” in *IEEE Int. Conf. Data Mining (ICDM)*, 2008, pp. 413–422.
- [15] K. S. Killourhy and R. A. Maxion, “Comparing Anomaly-Detection Algorithms for Keystroke Dynamics,” in *IEEE/IFIP DSN*, 2009, pp. 125–134.
- [16] I. Goodfellow, Y. Bengio, and A. Courville, *Deep Learning*. Cambridge, MA: MIT Press, 2016.
- [17] J. Gama, I. Žliobaitė, A. Bifet, M. Pechenizkiy, and A. Bouchachia, “A Survey on Concept Drift Adaptation,” *ACM Comput. Surv.*, vol. 46, no. 4, pp. 1–37, 2014.
- [18] Hyperledger Foundation, “Hyperledger Fabric Documentation, v2.5,” Linux Foundation, 2024.
- [19] National Institute of Standards and Technology, “Blockchain Technology Overview,” NISTIR 8202, 2018.
- [20] National Institute of Standards and Technology, “Security and Privacy Controls for Information Systems and Organizations,” NIST SP 800-53 Rev. 5, 2020.
- [21] Brasil, “Lei n. 13.709/2018 – Lei Geral de Proteção de Dados Pessoais (LGPD),” 2018.